

ISCY Handbuch

Version: Arbeitsstand Juni 2026 (ISCY V23.7.15 / Rust 0.3.11)

Dieses Handbuch erklart ISCY fachlich und in einfacher Sprache. Es ist fuer Menschen geschrieben, die nicht aus einem ISMS-, Compliance- oder Informationssicherheits-Umfeld kommen.

ISCY wurde in dieser Codebasis mit Unterstuetzung von OpenAI Codex entwickelt, nach Rust migriert und technisch/fachlich plausibilisiert. Die fachliche Ausrichtung wurde gegen offizielle EU-Quellen zu NIS2, der NIS2-Durchfuehrungsverordnung (EU) 2024/2690, DORA, Cyber Resilience Act und EU AI Act sowie gegen gaengige ISMS-, Product-Security-, CVE-/SBOM-/CSAF-, Evidence- und Incident-Response-Praktiken geprueft. Das ist keine externe Zertifizierung und keine Rechtsberatung, aber eine nachvollziehbare fachliche Arbeitsgrundlage.

1. Was ISCY ist

ISCY ist eine Arbeitsplattform fuer:

- den Aufbau und die Pflege eines ISMS nach ISO 27001
- die Einordnung regulatorischer Anforderungen wie NIS2 und KRITIS
- die Planung, Bewertung und Nachverfolgung von Risiken
- die Dokumentation von Nachweisen, Audits und Management Reviews
- die strukturierte Bearbeitung von Produkt- und Software-Sicherheitsfragen
- die Bewertung von Schwachstellen und CVEs mit lokalem LLM-Enrichment
- die Auswertung von Zero-Trust-Agent-Posture fuer Windows, macOS und Linux

ISCY ist damit kein reines Ticketsystem und kein reines DMS. Es verbindet Governance, Nachweise, Risiken, Umsetzungsplanung und Produkt-Sicherheit in einem gemeinsamen Arbeitsmodell.

2. Grundprinzipien in einfacher Sprache

2.1 Tenant

Ein Tenant ist in ISCY die organisatorische Einheit, fuer die gearbeitet wird. Das kann zum Beispiel sein:

- ein Unternehmen
- eine Gesellschaft
- eine Business-Plattform
- ein Mandant in einer Beratungs- oder Gruppenstruktur

Fast alle Daten in ISCY gehoeren zu genau einem Tenant. Dadurch bleiben Daten voneinander getrennt.

2.2 Assessment Session

Eine Assessment Session ist ein strukturierter Bewertungsdurchlauf. In ihr werden Profil, Scope, regulatorische Betroffenheit, Reifegrad und Ergebnisse zusammengefasst.

2.3 Requirement

Ein Requirement ist eine Anforderung. Das kann eine ISO-27001-Anforderung, eine NIS2-bezogene Pflicht oder eine interne Vorgabe sein.

2.4 Evidence

Evidence ist ein Nachweis. Zum Beispiel:

- eine Richtlinie
- ein Screenshot
- ein Auditprotokoll
- eine Verfahrensanweisung
- ein Export aus einem Drittsystem

2.5 Risk

Ein Risk beschreibt ein moegliches negatives Ereignis fuer das Unternehmen. In ISCY wird ein Risiko ueber Auswirkung und Eintrittswahrscheinlichkeit bewertet.

2.6 Roadmap

Die Roadmap uebersetzt Analyseergebnisse in konkrete Umsetzungsarbeit. Sie beantwortet die Frage: Was tun wir wann und warum?

2.7 CVE

Eine CVE ist eine bekannte Schwachstelle mit standardisierter Kennung, zum Beispiel CVE-2026-12345.

2.8 Zero-Trust Agent

Der Zero-Trust Agent ist ein read-only Collector. Er meldet Inventar, Heartbeats und Posture-Findings an ISCY. Produktive Agenten koennen mit Enrollment-Token aufgenommen werden und melden danach mit einem Agent-Secret, optional gebunden an einen mTLS-Client-Zertifikat-Fingerprint. Daraus entstehen keine automatischen Systemaenderungen, sondern nachvollziehbare Sichtbarkeit fuer Assets, Risiken, Evidenzen und Roadmap-Arbeit.

3. Wie man ISCY fachlich lesen sollte

ISCY folgt fachlich einem roten Faden:

1. Organisation verstehen
2. Scope und Relevanz bestimmen
3. Anforderungen und Reifegrad bewerten

4. Risiken ableiten
5. Nachweise sammeln
6. Massnahmen planen
7. Audits, Reviews und Reports durchfuehren
8. Produkt- und Schwachstellen-Themen integrieren

4. Navigation und Funktionsbereiche

Die wichtigsten Bereiche sind:

- Start-Wizard unter /
- Guidance Navigator unter /navigator/
- Dashboard unter /dashboard/
- Zero Trust unter /zero-trust/
- Catalog unter /catalog/
- Reports unter /reports/
- Roadmap unter /roadmap/
- Evidence unter /evidence/
- Assets unter /assets/
- Imports unter /imports/
- Processes unter /processes/
- Requirements unter /requirements/
- Risks unter /risks/
- Assessments unter /assessments/
- Organizations unter /organizations/
- Product Security unter /product-security/
- Vulnerability Intelligence unter /cves/

5. Fachliche Erkl  rung aller Hauptfunktionen

5.1 Organizations

Zweck: Die Stammdaten des Mandanten erfassen.

Was hier gepflegt wird:

- Name und Identitaet des Unternehmens oder Mandanten
- Land und Einsatzlaender
- Sektor
- Groessenindikatoren wie Mitarbeitendenzahl und Umsatz
- kritische Dienstleistungen
- Relevanz fuer NIS2 oder KRITIS
- Product-Security-Kontext

Fachlicher Nutzen:

- Grundlage fuer regulatorische Einordnung

- Grundlage fuer spaetere Berichte und Filter
- Entscheidungshilfe fuer NIS2-/KRITIS-Betroffenheit

Fuer Nicht-Sicherheitsleute: Dies ist die Stammdatenakte des Unternehmens in ISCY.

5.2 Wizard

Zweck: Den Nutzer Schritt fuer Schritt durch eine Erst- oder Neubewertung fuehren.

Schritte:

- Start
- Profil
- Applicability
- Scope
- Maturity
- Results

Fachlicher Nutzen:

- strukturiertes Onboarding in das Thema
- erste regulatorische Einordnung
- erste Reifegrad-Sicht
- Grundlage fuer Reports und Roadmap

Fuer Nicht-Sicherheitsleute: Der Wizard ist der gefuehrte Fragebogen, der aus Eingaben verwertbare Ergebnisse macht.

5.3 Guidance Navigator

Zweck: Orientierung geben, welche fachlichen Schritte als naechstes sinnvoll sind.

Typische Inhalte:

- Arbeitspakete
- empfohlene Reihenfolge
- Status der Bearbeitung
- Detailseiten zu einzelnen Schritten

Fachlicher Nutzen:

- priorisierte Navigation
- weniger Leerlauf und weniger doppelte Arbeit
- bessere Anschlussfaehigkeit fuer neue Nutzer

Fuer Nicht-Sicherheitsleute: Das ist die fachliche Landkarte durch das System.

5.4 Dashboard

Zweck: Management-taugliche Uebersicht ueber den aktuellen Stand.

Typische Inhalte:

- aggregierte Kennzahlen
- sektor- oder tenantbezogene Sicht
- Portfolio-PDF

Fachlicher Nutzen:

- schneller Statusblick
- Kommunikation an Leitung, Programmsteuerung oder Kunden

Fuer Nicht-Sicherheitsleute: Das Dashboard ist das Cockpit.

5.5 Catalog

Zweck: Normative und fachliche Struktur sichtbar machen.

Typische Inhalte:

- Domänen
- Struktur fuer Anforderungen
- fachliche Referenzbasis

Fachlicher Nutzen:

- gemeinsames Vokabular
- Vergleichbarkeit von Assessments

Fuer Nicht-Sicherheitsleute: Der Catalog ist das Inhaltsverzeichnis der Bewertungslogik.

5.6 Requirements

Zweck: Anforderungen sichtbar und bearbeitbar machen.

Typische fachliche Fragen:

- Welche Pflicht existiert?
- Gilt sie fuer unseren Scope?
- Wie gut ist sie umgesetzt?
- Wo fehlt noch Nachweis?

Fachlicher Nutzen:

- Uebersicht ueber Soll-Anforderungen
- Bruecke zwischen Norm, Praxis und Nachweis

Fuer Nicht-Sicherheitsleute: Hier steht, was man tun oder dokumentieren muss.

5.7 Processes

Zweck: Geschaeftsprozesse im Scope darstellen.

Typische Inhalte:

- Prozessname
- Scope
- Beschreibung
- Status
- Zuordnung zu Bereichen

Fachlicher Nutzen:

- Risiken und Anforderungen an echte Geschäftsabläufe anbinden
- Verantwortungen klarer machen

Für Nicht-Sicherheitsleute: Ein Prozess ist ein geordneter Arbeitsablauf des Unternehmens.

5.8 Assets

Zweck: Informationswerte und wichtige Objekte dokumentieren.

Typische Asset-Beispiele:

- Anwendungen
- Datenbestände
- Infrastruktur
- Services
- Dokumentationen

Fachlicher Nutzen:

- Risiken an konkrete Werte koppeln
- Kritikalität nachvollziehbar machen

Für Nicht-Sicherheitsleute: Assets sind die Dinge, die für das Unternehmen wichtig sind und geschützt werden müssen.

5.8.1 Zero Trust

Zweck: Endpoint- und Infrastruktur-Posture aus Agenten sichtbar machen.

Typische Inhalte:

- registrierte Agent-Devices
- letzter Heartbeat
- Zero-Trust-Score
- nächster fachlicher Fokus aus Score, Severity und Agent-Freshness
- offene Findings nach Pillar und Severity
- Check-Katalog für Windows, macOS und Linux

Fachlicher Nutzen:

- technische Posture mit ISMS-Arbeit verbinden
- Findings in Risiken, Evidenzen und Roadmap-Arbeit überführen

- Zero-Trust-Optimierung nachvollziehbar und auditierbar machen
- Prioritaeten schneller erkennen, ohne Rohdaten manuell vergleichen zu muessen

Fuer Nicht-Sicherheitsleute: Der Bereich zeigt, welche Geraete welche Sicherheit-sluecken oder Nachweise melden.

Was die Agenten aktuell testen koennen:

- Inventar: Hostname, OS-Familie, OS-Version, CPU-Architektur, Agent-Version und Deployment-Channel
- Heartbeat: ob ein registriertes Geraet noch regelmaessig mit ISCY spricht
- OS-Baseline: Betriebssystem- und Patch-/Versionshinweise als Grundlage fuer MDM- oder Patch-Nachweise
- Datentraeger-Verschluesselung: BitLocker unter Windows, FileVault unter macOS, LUKS/root encryption unter Linux
- Plattformintegritaet: Secure Boot unter Windows/Linux sowie SIP/authenticated root unter macOS
- Host-Firewall: Windows-Firewall-Profile, macOS Application Firewall, Linux firewalld/ufw/nftables/iptables-Signale
- MDM oder Endpoint Management: Windows Enrollment Registry, macOS profiles-Enrollment, Linux-Management-Agenten wie osquery, Puppet, Chef, Salt, SSM oder vergleichbare Agenten
- Endpoint Protection/EDR: Windows Defender Status, macOS EDR-/Security-Agent-Pfade, Linux-Dienste und Pfade fuer Wazuh, auditd, Microsoft Defender, CrowdStrike, SentinelOne, osquery und vergleichbare Agenten

Die Agenten arbeiten read-only. Wenn ein Signal nicht sicher bestaetigt werden kann, meldet ISCY eine offene Evidenzluecke statt einen erfundenen Nachweis.

Die Weboberflaeche stellt Zero Trust bewusst als Arbeitsansicht dar:

- Score-Karte fuer die aktuelle Zero-Trust-Reife
- Fokuskarte fuer den naechsten sinnvollen Schritt
- Severity-Badges fuer kritische, hohe, mittlere und niedrige Findings
- mobile Navigation und horizontal scrollbare Tabellen fuer kleine Displays
- konservative Darstellung ohne automatische Remediation

5.9 Risks

Zweck: Risiken erfassen, bewerten und behandeln.

Kernlogik:

- Beschreibung des Risikos
- Bedrohung
- Schwachstelle
- Impact

- Likelihood
- Risikostufe
- Behandlungsstrategie
- Fristen und Reviews
- Review-Workflow fuer Behandlung, Akzeptanz, Mitigation und Abschluss
- automatische CVE-Risiken aus akzeptierten Product-Security-Korrelationen

Fachlicher Nutzen:

- zentrales Risikoregister
- transparente Priorisierung
- Nachvollziehbarkeit von Entscheidungen
- fachlicher Review von automatisch erzeugten Schwachstellenrisiken

Fuer Nicht-Sicherheitsleute: Ein Risiko ist in ISCY kein Technikfehler, sondern eine moegliche negative Geschaeftsauswirkung.

5.10 Assessments

Zweck: Umsetzungs- und Nachweisstand strukturiert dokumentieren.

Teilfunktionen:

- Applicability fachliche Frage: Gilt eine Anforderung fuer uns?
- Measures fachliche Frage: Welche Massnahme setzen wir um?
- Statement of Applicability (SoA) fachliche Frage: Welche ISO-27001 Controls sind relevant, umgesetzt oder ausgeschlossen?
- Audits fachliche Frage: Was wurde geprueft und was wurde gefunden?
- Findings fachliche Frage: Welche Abweichungen oder Schwachstellen wurden festgestellt?
- Management Reviews fachliche Frage: Wie bewertet die Leitung den Gesamtstand?
- Review Actions fachliche Frage: Welche Folgeaktionen beschliesst die Organisation?

Fachlicher Nutzen:

- Kernbereich fuer ISMS-Nachweisfuehrung
- interne und externe Auditvorbereitung
- Management-Einbindung

Fuer Nicht-Sicherheitsleute: Hier wird aus "wir glauben, dass wir gut sind" ein belastbarer und pruefbarer Nachweis.

5.11 Evidence

Zweck: Nachweise sammeln, pflegen und mit Bedarfen verknuepfen.

Typische Funktionen:

- Evidence hochladen
- Evidence aktualisieren
- Evidence Needs synchronisieren
- Evidence direkt aus Risks, Roadmap-Tasks, Incidents und Product-Security-Kontexten vorbefüllen
- nach dem Speichern automatisch zur Ausgangsseite zurueckkehren

Fachlicher Nutzen:

- Nachweisfuehrung an einem Ort
- bessere Auditfaehigkeit
- weniger Suche nach Dokumenten
- klarere Rueckverfolgbarkeit durch stabile Linked-Requirement- und Evidence-Key-Bezuege

Fuer Nicht-Sicherheitsleute: Evidence ist der Ordner mit den Belegen, aber strukturiert und auswertbar.

5.12 Reports

Zweck: Ergebnisse in lesbare und versendbare Form bringen.

Ausgaben:

- Report-Detailseite
- einfaches PDF
- audit-faehiges PDF

Fachlicher Nutzen:

- Management-Kommunikation
- Dokumentationsstand
- Vorlagen fuer Kunden, Auditoren oder interne Gremien

Fuer Nicht-Sicherheitsleute: Reports sind die offizielle Zusammenfassung des Stands.

5.13 Roadmap

Zweck: Aus Ergebnissen konkrete Arbeit machen.

Typische Funktionen:

- Planliste
- Plandetail
- Kanban-Ansicht
- Task-Bearbeitung
- PDF- und PNG-Export
- direkte Evidence-Verknuepfung je Roadmap-Task

Fachlicher Nutzen:

- Transformation von Analyse in Umsetzungsprogramm
- Priorisierung nach Wirkung und Aufwand
- Nachweisfuehrung dort starten, wo die Umsetzungsarbeit entsteht

Fuer Nicht-Sicherheitsleute: Die Roadmap ist der Umsetzungsfahrplan.

5.14 Import Center

Zweck: Bestehende Daten strukturiert nach ISCY uebernehmen.

Typische Funktionen:

- Import Guide
- Mapping Assistant
- Vorschau
- Template-Download

Importierbare Inhalte:

- Business Units
- Prozesse
- Lieferanten
- Assets

Fachlicher Nutzen:

- schneller Projektstart
- weniger manuelle Datenerfassung
- bessere Datenqualitaet durch Mapping

Fuer Nicht-Sicherheitsleute: Das Import Center ist die Uebersetzungsstelle fuer vorhandene Tabellen in das ISCY-Datenmodell.

5.15 Product Security

Zweck: Sicherheitsaspekte digitaler Produkte verwalten.

Typische Objekte:

- Product Family
- Product
- Product Release
- Component
- AI System
- Threat Model
- Threat Scenario
- TARA
- Vulnerability
- PSIRT Case

- CSAF-/SBOM-Importhistorie
- CVE-Asset-Korrelation
- CVE-Risiko-Review-Queue

Fachlicher Nutzen:

- Anbindung von Produktentwicklung und Sicherheitsgovernance
- Vorbereitung fuer CRA, IEC 62443, ISO/SAE 21434 oder AI-bezogene Governance
- Sicht auf Releases, Komponenten und Verwundbarkeit
- strukturierte Verarbeitung von CSAF-Advisories, CycloneDX/SPDX-SBOMs und CVE-Korrelationen
- automatische Ableitung von Risiko- und Roadmap-Arbeit aus akzeptierten CVE-Korrelationen
- Nachweissteuerung ueber Evidence-Keys fuer CVE, Import, Risiko und Roadmap

Fuer Nicht-Sicherheitsleute: Dieser Bereich ist fuer Unternehmen wichtig, die Software, digitale Produkte oder vernetzte Systeme bereitstellen.

Aktueller Rust-Funktionsumfang:

- Import-Historie fuer CSAF, CycloneDX und SPDX mit CSV-/JSON-Export
- Import-Detailseite mit Validierungsfehlern und Komponenten-Matches
- CVE-Asset-Korrelation ueber CPE oder PURL mit Akzeptieren/Ablehnen-Workflow
- automatische Erzeugung von CVE-Risiken und Product-Security-Roadmap-Tasks aus akzeptierten Korrelationen
- Dashboard-Kennzahlen fuer offene CVE-Reviews und fehlende Evidence
- gebuendelte CVE-Risiko-Review-Queue mit Filtern fuer offene Reviews, fehlende Evidence und fehlende Risiken
- Bulk-Aktionen fuer ausgewaehlte CVE-Reviews: Risiko/Roadmap erzeugen, Behandlung freigeben, Restrisiko akzeptieren oder als mitigiert markieren
- Einzelaktionen fuer Behandeln, Akzeptieren und Mitigiert markieren
- Evidence-Vorbefuellung und Ruecksprung zur Ausgangsseite nach Upload

5.16 Vulnerability Intelligence

Zweck: Bekannte Schwachstellen fachlich und technisch bewerten.

Was der Bereich jetzt leisten soll:

- CVE aus NVD laden
- lokale Risikoanalyse durchfuehren
- optionales lokales LLM-Enrichment
- EPSS- und KEV-Kontext beruecksichtigen
- NIS2-Relevanz und kritische Services einbeziehen
- Git-/Repository- und Paketkontext speichern
- Risiko- und Vulnerability-Objekte automatisch verknuepfen

Fuer lokale Tests und air-gapped Prueflaeufe kann der NVD-Import statt eines HTTP-Endpunkts auch eine lokale NVD-JSON-Datei lesen, wenn `NVD_API_BASE_URL` als `file:///pfad/zur/nvd-response.json` gesetzt wird.

Fachlicher Nutzen:

- bessere Priorisierung als nur CVSS
- Verbindung zwischen Technik, Betrieb und Regulierung
- Grundlage fuer PSIRT, Patch-Steuerung und Management-Kommunikation

Fuer Nicht-Sicherheitsleute: Hier wird aus einer technischen Schwachstellenmeldung eine geschaeftlich nutzbare Bewertung.

6. Typische Arbeitsablaeufe

6.1 Erstaufbau eines ISMS

1. Tenant anlegen
2. Wizard durchlaufen
3. Prozesse, Assets und Lieferanten importieren
4. Requirements und Applicability sichten
5. erste Risiken erfassen
6. Evidence aufbauen
7. SoA generieren
8. Report und Roadmap erzeugen

6.2 Auditvorbereitung

1. offene Findings und Reviews sichten
2. Evidence Needs synchronisieren
3. Nachweise aktualisieren
4. SoA pruefen
5. Audit-Report erzeugen

6.3 NIS2-orientierte Arbeitsweise

1. Tenant als NIS2-relevant markieren
2. kritische Services klar beschreiben
3. Prozesse, Assets und Risiken auf wesentliche Dienste beziehen
4. Schwachstellen mit NIS2-Kontext bewerten
5. Reports fuer Leitung und Nachweiszwecke verwenden

6.4 Produkt- und Schwachstellensteuerung

1. Produkte, Releases und Komponenten pflegen
2. CSAF-Advisories oder SBOMs importieren und Validierungsfehler pruefen
3. Komponenten-Matches ueber CPE oder PURL kontrollieren
4. CVE-Asset-Korrelationen vorschlagen lassen

5. Korrelationen fachlich akzeptieren oder ablehnen
6. Aus akzeptierten Korrelationen Risiko- und Roadmap-Arbeit erzeugen
7. CVE-Risiko-Review-Queue abarbeiten
8. Evidence direkt aus Queue, Risiko oder Roadmap-Task hochladen
9. Massnahmen ueber Roadmap oder Risiko-Behandlung steuern

6.5 Incident- und NIS2-Meldeworkflow

Die Rust-Webroute `/incidents/` fuehrt operative Sicherheitsvorfaelle als mandanten-faehige Fallakten. Ein Incident kann Reporter, Owner, Risiko, Asset und Prozess referenzieren und enthaelt Typ, Runbook, Status, Severity, Stakeholder-Zusammenfassung sowie Behoerden- oder Case-Referenz. Tenantbezogene Runbook-Vorlagen werden in `incidents_runbooktemplate` gepflegt, per `/api/v1/incidents/runbook-templates` ausgeliefert und koennen beim Anlegen eines Incidents direkt als bearbeitbare Startvorlage uebernommen werden.

ISCY trennt bewusst zwischen einem Security Incident und einem erheblichen Sicherheitsvorfall. Nicht jeder operative Sicherheitsvorfall ist automatisch NIS2-meldepflichtig. Die Fallakte kann deshalb zuerst als normaler Incident entstehen und danach fachlich bewertet werden.

Die NIS2-Erheblichkeitsentscheidung wird in ISCY mit vier Status gefuehrt:

1. Nicht bewertet
2. Nicht erheblich
3. Wahrscheinlich erheblich
4. Erheblich / NIS2 meldepflichtig

Zur Begrueundung koennen Kriterien, Entscheidungstext, Referenz und Bewertungszeitpunkt gepflegt werden. Fachlich orientiert sich die Bewertung an NIS2 Art. 23. Die Durchfuehrungsverordnung (EU) 2024/2690, insbesondere Art. 3, wird in ISCY als Best-Practice-Referenz genutzt, auch wenn ihr unmittelbarer Pflichtbereich nur bestimmte Entitaeten betrifft. Dadurch wird sichtbar, warum ein Fall meldepflichtig ist oder warum er bewusst nicht als erheblicher Sicherheitsvorfall behandelt wird.

Erst wenn ein Incident auf Erheblich / NIS2 meldepflichtig gesetzt wird, berechnet ISCY die relevanten Fristen aus dem Erkennungszeitpunkt:

1. 24h-Fruehwarnung
2. 72h-Meldung
3. Abschlussbericht nach 30 Tagen

Die Uebersicht zeigt offene Faelle, Erheblichkeitsstatus, NIS2-relevante Faelle und ueberfaellige Meldeschritte. Gesendete Meldungen koennen ueber die API als Zeitstempel gepflegt werden. Damit vermeidet ISCY eine Angstlogik nach dem Motto

“24 Stunden fuer alles” und erzwingt stattdessen eine nachvollziehbare fachliche Entscheidung.

Die Detailseite `/incidents/{id}` dient als operative Fallakte. Dort koennen berechnigte Rollen Typ, Runbook, Status, Severity, Erheblichkeitsentscheidung, Behoerdenreferenz, Zeitlinie und Meldezeitpunkte pflegen; die Runbook-Bibliothek wird als Referenz direkt neben der Fallakte angezeigt. ISCY dokumentiert die Anlage der Fallakte, Statuswechsel, NIS2-Erheblichkeitsaenderungen, manuelle Timeline-Notizen und incidentbezogene Evidence-Uploads als Timeline-/Audit-Events mit Actor, Zeitpunkt, Ereignisart und Detailtext. Manuelle Notizen koennen auch ueber `POST /api/v1/incidents/{id}/timeline-notes` automatisiert erfasst werden. Evidence-Uploads koennen ueber `incident_id` direkt an einen Incident gekoppelt werden und erscheinen in der Fallakte; fuer berechnigte Rollen steht der Upload direkt auf der Incident-Detailseite bereit. Alertmanager-Fallakten werden ueber Fingerprint oder Alertname dedupliziert; resolved Alerts schliessen passende offene Fallakten automatisch und sind in `/operations/incidents/` als Betriebsuebersicht mit Filtern fuer open, critical und resolved sichtbar. Optional kann `ISCY_ALERTMANAGER_REQUIRE_RESOLUTION_REVIEW=1` gesetzt werden, damit automatisch geschlossene Alert-Fallakten ohne Lessons Learned als Review-Pflicht fuer Root Cause und Lessons Learned markiert werden. Das Meldepaket unter `/incidents/{id}/nis2-export` buendelt Fallakte, NIS2-Erheblichkeitsentscheidung, Runbook, verknuepfte Evidence, Audit-Timeline, betroffene Bezuege, 24h-/72h-/30-Tage-Fristen, Stakeholder-Zusammenfassung und Lessons Learned; zusaetzlich stehen HTML und PDF ueber `/incidents/{id}/nis2-export.html` und `/incidents/{id}/nis2-export.pdf` bereit.

6.6 SOC-Playbook fuer Phishing- und aehnliche Incident-Faelle

Empfohlene Kette fuer die operative Bearbeitung:

1. Scope bestimmen
Klaeren, wer und was betroffen ist, seit wann der Vorfall laeuft und welche Systeme, Konten, Daten oder Geschaeftsbereiche im Risiko stehen.
2. Informationen korrelieren
Mail-Logs, SEG, SIEM, EDR, Auth-, Proxy-, DNS- und Firewall-Daten zusammenfuehren.
3. Nach Gemeinsamkeiten suchen
IOCs und TTPs vergleichen (Domain, URL, Hash, Prozesse, Zeitfenster, Zielgruppe).
4. Vorfall bewerten
Einordnen, ob Spam, Phishing, BEC, Malware Delivery oder bereits Account Compromise vorliegt.
5. Verdacht bestaetigen
Von der Hypothese in die Incident-Response wechseln, sobald belastbare Evidenz vorliegt.

6. Priorisieren
Kritikalitaet und Dringlichkeit anhand Impact, Privilege-Level, Ausbreitungs- und Datenabflussrisiko einstufen.
7. Dokumentieren
Nachvollziehbar festhalten, was bekannt ist, was vermutet wird, was getan wurde und warum.
8. Containment einleiten
Sofortmassnahmen risikobasiert umsetzen (z. B. Mail entfernen, URL blockieren, Session widerrufen, Konto sichern, Host isolieren).
9. Gegebenenfalls eskalieren
An L2/L3, IR, IAM, Management, Datenschutz oder Legal uebergeben, wenn Risiko, Scope oder Komplexitaet es erfordern.

Merksatz: Erst verstehen, dann bewerten, dann eindaemmen, dann eskalieren - wenn Risiko oder Komplexitaet es verlangen.

6.7 ISCY lokal auf NixOS starten

Einfachster lokaler Start:

```
cd /home/enricow79/Projekte/ISCY
./start.sh
```

Danach ist ISCY unter <http://127.0.0.1:9000/login/> erreichbar.

Demo-Login:

admin / Admin123!

Ohne Wrapper kann der Rust-Service so initialisiert und gestartet werden:

```
nix run .#iscy-backend -- init-demo
DATABASE_URL=sqlite:///db.sqlite3 RUST_BACKEND_BIND=127.0.0.1:9000 nix
run .#iscy-backend
```

Maschinenlesbarer Betriebsstatus fuer lokale Pruefung, Monitoring und Agenten:

```
curl -fsS http://127.0.0.1:9000/health/live
curl -fsS http://127.0.0.1:9000/status/operations.json
curl -fsS http://127.0.0.1:9000/metrics
```

Alertmanager kann Betriebsalarme an ISCY melden:

```
curl -fsS -X POST http://127.0.0.1:9000/api/v1/operations/alertmanager \
-H 'content-type: application/json' \
-d '{"receiver": "iscy-operations", "status": "firing", "alerts": []}'
```

Ohne Tenant-/User-Kontext wird der Alert nur normalisiert. Mit schreibendem Tenant-Kontext erzeugt ISCY fuer firing Alerts automatisch eine Incident-Fallakte, verknuepfte Evidence und einen Timeline-Eintrag. Wiederholte firing Alerts werden dedupliziert, resolved Alerts schliessen die passende offene Alert-Fallakte automa-

tisch. Die Alert-Operations-Seite `/operations/incidents/` bietet direkte Filter fuer `open`, `critical` und `resolved`. Wird `ISCY_ALERTMANAGER_REQUIRE_RESOLUTION_REVIEW=1` gesetzt, markiert ISCY automatisch geschlossene Alert-Fallakten ohne Lessons Learned als Review-Pflicht. Das Monitoring-Beispiel nutzt fuer lokale Demo-Stacks Tenant 1, User 2 und Rolle `CONTRIBUTOR`; User 2 ist der per Demo-Seed angelegte technische Operations-User `ops-alertmanager`.

Mit Tenant-Kontext enthaelt der Betriebsstatus zusaetzlich fachliche Signale zu ISCY-27, Product Security, offenen CVE-Reviews, fehlender Evidence, Migrationen, Runtime-Flags und verbundenen Rust-Modulen:

```
curl -fsS -H 'x-iscy-tenant-id: 1' -H 'x-iscy-user-id: 1' \
  'http://127.0.0.1:9000/api/v1/status/operations?tenant_id=1&user_id=1'
curl -fsS -H 'x-iscy-tenant-id: 1' -H 'x-iscy-user-id: 1' \
  'http://127.0.0.1:9000/api/v1/status/metrics?tenant_id=1&user_id=1'
```

Die Prometheus-/Grafana-Betriebsdoku liegt in `docs/OPERATIONS_MONITORING.md`.

Fuer den direkten Monitoring-Betrieb liegen diese Artefakte im Repository:

- `deploy/monitoring/prometheus/iscy-scrape.yml`
- `deploy/monitoring/prometheus/iscy-operations-alerts.yml`
- `deploy/monitoring/alertmanager/iscy-alertmanager.yml`
- `deploy/monitoring/grafana/iscy-operations-dashboard.json`
- `deploy/monitoring/docker-compose.yml`
- `deploy/monitoring/nixos/iscy-monitoring.nix`
- `deploy/monitoring/nixos/example-host.nix`

Die Statusseite `/status/` zeigt neben Health, Migrationen, Modulen, offenen Signalen und Prometheus-Scrape-Konfiguration auch einen kompakten Grafana-Query-Spickzettel sowie direkte Links zu Incident-Fallakten und `/operations/incidents/`. Das Grafana-Dashboard enthaelt zusaetzlich Panels fuer Alert-Incidents mit konfigurierbarer `iscy_base_url`, konkretem Incident-Drilldown ueber `iscy_operations_alertmanager_incident_info`, Product-Security-Coverage, CVE-Review-Trend und Importvalidierung.

Der Product-Security-Bereich zeigt zusaetzlich Trenddaten fuer SBOM-/CSAF-/Threat-Coverage, offene CVE-Reviews, fehlende Evidence, Importvalidierung und Snapshot-Verlauf. Maschinenlesbar sind diese Daten ueber `GET /api/v1/product-security/trends` und ueber Prometheus-Metriken wie `iscy_product_security_trend_signal`, `iscy_product_security_coverage_percent` und `iscy_product_security_import_validation_total`.

Runbook fuer automatisch erzeugte Alert-Incidents:

1. Neue Fallakte in `/operations/incidents/` sichten, bei Bedarf nach `open`, `critical` oder `resolved` filtern und in `/incidents/` oeffnen.

2. Severity, Scope und betroffene Services pruefen.
3. Automatische Evidence kontrollieren und bei Bedarf Grafana-/Log-Nachweise nachreichen.
4. Owner, Eindämmung, Kommunikation, NIS2-Erheblichkeit und weitere regulatorische Relevanz bewerten.
5. Nach Behebung Timeline, Root Cause, Lessons Learned und Alert-Schwelle reviewen.

Wichtige lokale Pruefbefehle:

```
nix develop --command make rust-smoke
nix develop --command make team-test
make rust-test
make rust-smoke
make team-test
nix flake check
```

Agent-Payload lokal testen:

```
nix run .#iscy-agent -- --self-test
```

Agent an eine lokale ISCY-Instanz melden lassen:

```
ISCY_BACKEND_URL=http://127.0.0.1:9000 \
ISCY_TENANT_ID=1 \
ISCY_USER_ID=1 \
nix run .#iscy-agent
```

Produktive Agenten sollten mit Enrollment-Token aufgenommen werden:

```
ISCY_BACKEND_URL=http://127.0.0.1:9000 \
ISCY_TENANT_ID=1 \
ISCY_AGENT_ENROLLMENT_TOKEN=<token> \
nix run .#iscy-agent
```

Merksatz: Erst ISCY starten, dann den Agent per --self-test pruefen, danach mit Token oder Agent-Secret an die Plattform melden.

6.7 Docker-Betrieb in einfacher Sprache

Wenn du ISCY schnell und reproduzierbar starten willst, nutze Docker.

1. make docker-check
Prueft zuerst alle Compose-Dateien auf Syntax und Zusammenbau.
2. make docker-smoke
Startet eine kurze Rust-Funktionsprobe (DB, Healthcheck und zentrale API-Probes) und faehrt danach wieder herunter.
3. Danach den gewuenschten Modus starten
 - lokal: make dev-up
 - stage: make stage-up

- produktiv: `make prod-up` oder `make prod-up-llm`

Merksatz: Erst validieren, dann kurz testen, dann dauerhaft starten.

6.8 CRA, IoT/Cloud, Windows, OT und Produktionsarchitektur (einfach erklart)

Stand dieser Anleitung: 18. April 2026.

CRA (Cyber Resilience Act) in kurz

- Der CRA ist seit Dezember 2024 in Kraft.
- Meldepflichten starten ab 11. September 2026.
- Die wesentlichen Pflichten gelten ab 11. Dezember 2027.

Fuer ISCY bedeutet das praktisch:

1. Produkt-Scope und Komponenten sauber pflegen.
2. Schwachstellen- und Patch-Prozess dokumentieren.
3. Incident- und Meldewege frueh vorbereiten.
4. Nachweise (Evidenz) revisionsfest ablegen.

IoT- und Cloud-Security in kurz

- IoT: Asset-Inventar, sichere Defaults, Updatefaehigkeit, Segmentierung.
- Cloud: Identitaeten haerten, Logs zentral sammeln, Konfigurationen regelmaessig pruefen.
- In ISCY: Prozesse, Assets, Risiken und Massnahmen zusammenfuehren.

Windows-Hardening in kurz

- Admin-Rechte minimieren.
- MFA, starke Authentisierung und Session-Kontrollen aktivieren.
- Security-Baselines und Patch-Stand regelmaessig pruefen.
- Ueber ISCY als Prozess + Evidenz + Review dokumentieren.

OT-Security und Produktionssysteme (OPC UA, MES, SCADA, IdentPro)

- IT und OT klar trennen (Zonen/Segmente).
- Fernzugriffe streng kontrollieren.
- Kritische Schnittstellen (z. B. OPC UA, MES, SCADA, Identitaetsprovider) inventarisieren.
- Notfall- und Wiederanlaufablaeufoe fuer Produktion ueben.
- In ISCY als Risiko, Massnahme, Evidenz und Incident-Playbook abbilden.

Merksatz: Technik, Organisation und Nachweis muessen zusammenpassen.

6.9 Einfache Abnahme-Checkliste fuer die neuen Themen

Nutze diese Liste als schnelle Team-Abnahme in ISCY:

1. Docker laeuft stabil

- `make docker-check` ist ohne Fehler durchgelaufen.

- make docker-smoke ist ohne Fehler durchgelaufen.
- 2. CRA-Readiness sichtbar
 - Product-Security-Scope ist gepflegt.
 - Schwachstellen-/Patch-Prozess ist dokumentiert.
 - Incident-/Meldeweg ist dokumentiert.
- 3. Cloud-Security umgesetzt
 - Cloud-Services sind inventarisiert.
 - Cloud-Identitäten/Schlüssel folgen Least-Privilege.
- 4. Windows-Hardening umgesetzt
 - Baselines sind definiert.
 - lokale Adminrechte, Makros, SMB und Firewall sind geregelt.
- 5. OT-/Produktions-Security umgesetzt
 - Zonen/Conduits sind dokumentiert.
 - OPC UA, MES, SCADA und Produktions-Identitäten sind abgesichert.
- 6. Nachweise vorhanden
 - Zu jedem Punkt gibt es in ISCY mindestens Prozess, Risiko oder Massnahme plus Evidenz.

Merksatz: Nicht nur planen - auch nachweisbar umsetzen.

6.10 Zero-Trust-Ausbaupfad

Grundschutz wird in diesem Arbeitsstand bewusst zurueckgestellt. Der sinnvolle naechste Fokus fuer ISCY ist Zero Trust als laufende technische Posture-Sicht.

Was aktuell belastbar vorhanden ist:

- Rust-only Backend mit Zero-Trust-Webansicht unter /zero-trust/
- read-only Agent fuer Windows, macOS und Linux
- Enrollment-Token, Agent-Secret und optionale mTLS-Fingerprint-Bindung
- Inventar, Heartbeat und lokale OS-/MDM-/EDR-Findings
- Scores nach Device und Pillar
- offene Findings nach Severity
- Fokuskarte fuer den naechsten fachlich sinnvollen Schritt

Was als naechstes fachlich am meisten bringt:

1. Agent-Abdeckung je Plattform messen

Pro Tenant sichtbar machen, wie viele Windows-, macOS- und Linux-Systeme erwartet werden und wie viele davon frisch melden.
2. Findings mit Risiken und Evidenzen verbinden

Aus wiederkehrenden High-/Critical-Findings sollten Risiken, Massnahmen und Evidenzanforderungen ableitbar sein.
3. MDM-/EDR-Integrationen vorbereiten

Intune, Jamf, Microsoft Defender, Wazuh, CrowdStrike oder SentinelOne sollten

zunaechst als Import-/Connector-Schicht angebunden werden, nicht als Fernsteuerung.

4. Softwareinventar und CVE-Korrelation ergaenzen
Agent- oder MDM-Inventar sollte mit dem CVE-Bereich verbunden werden, damit betroffene Systeme schneller sichtbar sind.
5. Ausnahme- und Ablaufdatum erzwingen
Akzeptierte Abweichungen sollten Owner, Begrueendung, Laufzeit und Wiedervorlage haben.
6. Signierte Agent-Pakete bauen
Windows MSI/Intune-Paket, macOS PKG/Jamf-Profil und Linux systemd-Pakete sind fuer produktive Rollouts wichtiger als weitere Einzelchecks.
7. Remediation getrennt halten
Automatische Aenderungen am Endgeraet sollten erst spaeter als signierter, auditierbarer Policy-Schritt kommen.

Fachliches Kurzurteil: ISCY ist fuer Zero Trust jetzt gut positioniert. Die naechste Reife entsteht nicht durch aggressivere Agenten, sondern durch bessere Abdeckung, Priorisierung, Nachweisverknuepfung und saubere Deployment-Pakete.

7. Was die wichtigsten Begriffe bedeuten

- ISO 27001: internationaler Standard fuer Informationssicherheits-Managementsysteme
- ISMS: Managementsystem fuer Informationssicherheit
- NIS2: EU-Regelwerk fuer Cybersecurity-Pflichten wesentlicher und wichtiger Einrichtungen
- KRITIS: Kritische Infrastrukturen
- SoA: Statement of Applicability, also die begruendete Auswahl und Bewertung von Controls
- Audit: systematische Pruefung
- Finding: Feststellung aus einer Pruefung
- Evidence: Nachweis
- CVE: standardisierte Kennung fuer eine bekannte Schwachstelle
- CVSS: Basisscore fuer technische Schwere
- EPSS: Wahrscheinlichkeitsmodell fuer die Ausnutzung einer Schwachstelle
- KEV: Liste bekannter aktiv ausgenutzter Schwachstellen
- TARA: Threat Analysis and Risk Assessment
- PSIRT: Product Security Incident Response Team

8. Was ISCY ausdruecklich nicht ersetzt

ISCY ersetzt nicht:

- eine Rechtsberatung

- eine vollautomatische Sicherheitsbewertung ohne Fachpruefung
- operative Patch- oder Deployment-Tools
- ein SIEM oder SOC
- ein vollwertiges Projektmanagement-Werkzeug fuer alle Unternehmensbereiche

ISCY strukturiert, dokumentiert, priorisiert und verbindet. Entscheidungen muessen trotzdem fachlich verantwortet werden.

9. Empfehlungen fuer die Einfuehrung

- mit einem Tenant und einem realen Scope starten
- lieber wenige, aber belastbare Daten pflegen
- Begriffe intern vereinheitlichen
- Nachweise frueh sammeln
- Risiken nicht technisch, sondern geschaeftlich formulieren
- Produkt- und Schwachstellenlogik nur dort aktivieren, wo sie wirklich gebraucht wird

10. Git-Bezug dieses Handbuchs

Dieses Handbuch ist bewusst als Markdown-Datei im Repository abgelegt, damit es:

- versioniert werden kann
- mit dem Produkt mitwaechst
- in Pull Requests geprueft werden kann